

Description of Work (DOW) for Mid Level DevSecOps: (SMA3)

1.1 Objectives

CBO maintains a hybrid cloud infrastructure environment supported by established DevSecOps practices, security baselines, and federal compliance frameworks. To advance its modernization initiatives, CBO seeks DevSecOps Engineering Services to augment existing engineering staff and expand upon established infrastructure automation, CI/CD pipeline capabilities, container orchestration, and security-hardened delivery practices. The objective is to extend and mature its existing infrastructure automation and secure software delivery capabilities.

1.2 Scope of Work

The Contractor shall provide qualified personnel to integrate seamlessly with CBO's engineering team, build upon established procedures and guidelines, and contribute meaningfully across the following areas:

- Infrastructure as Code (IaC) using Terraform and OpenTofu
- Configuration as Code (CaC) using Ansible
- CI/CD pipeline development and maintenance using GitHub Actions
- Container build, management, and orchestration using Docker and Kubernetes
- Security integration and compliance hardening aligned with CBO baselines and federal mandates

The Contractor will not be expected to design from scratch; rather, the engineer(s) will inherit existing patterns, adhere to CBO engineering standards, and incrementally enhance capabilities within an active production environment.

The Contractor personnel shall attend applicable stand-ups, sprint planning, and technical review sessions.

The Contractor shall work within CBO's established version control, change management, and peer review workflows. No changes shall be pushed to production environments without following CBO's change advisory process. The Contractor shall follow CBO's documentation standards for all deliverables and maintain clear records of changes made to shared codebases and pipelines.

The Contractor shall adhere to all CBO security policies, including but not limited to, access control requirements, acceptable use policies, and data handling procedures.

The scope of work includes, but is not limited to, the following activities:

Infrastructure as Code (IaC) — Terraform / OpenTofu

The Contractor shall maintain, extend, and improve existing Terraform and OpenTofu codebases used to provision and manage CBO's cloud and hybrid infrastructure. This includes writing modular, reusable configurations; managing state files and remote backends; performing plan/apply workflows within

approved change control processes; and refactoring legacy configurations to align with current engineering standards. The Contractor shall not introduce new tooling without prior CBO IRM approval.

Work Products: Updated IaC modules, state management documentation, configuration change logs

Configuration as Code (CaC) — Ansible

The Contractor shall develop and maintain Ansible playbooks and roles to automate system configuration, compliance enforcement, patch management, and application deployment across CBO's server and network infrastructure. All playbooks shall adhere to CBO's existing role structure, variable conventions, and inventory management standards.

Work Products: Ansible playbooks/roles, inventory documentation, execution logs

CI/CD Pipeline Development — GitHub Actions

The Contractor shall build, maintain, and improve GitHub Actions workflows to automate build, test, security scanning, and deployment processes for CBO software and infrastructure pipelines. Pipelines shall incorporate security gates including static analysis (SAST), dependency scanning, secrets detection, and policy-as-code validation. All workflow changes shall be peer-reviewed and comply with CBO's branching and approval standards.

Work Products: GitHub Actions workflow files, pipeline documentation, security gate integration report

Container Management — Docker and Kubernetes

The Contractor shall support containerized application delivery using Docker for image builds and Kubernetes for orchestration. Responsibilities include writing and maintaining Dockerfiles following image hardening best practices, managing Kubernetes manifests and Helm charts, supporting namespace and RBAC configuration, and assisting with cluster health monitoring and troubleshooting. All container images shall be scanned for vulnerabilities prior to deployment.

Work Products: Dockerfiles, Kubernetes manifests, Helm charts, image scan reports

Security Integration and Compliance Hardening

The Contractor shall integrate security practices throughout the software delivery lifecycle (Shift-Left security). This includes incorporating SAST/DAST scanning tools into pipelines, enforcing CIS benchmarks and CBO security baselines on infrastructure and container configurations, supporting NIST SP 800-53 and FISMA compliance requirements, and producing documentation to support audit and assessment activities.

Work Products: Security scanning configuration, compliance alignment documentation, hardening checklists

1.3 Key Personnel

The following role is anticipated to be required for this work and is considered Key Personnel, in accordance with SOW paragraph 2.9.

- DevSecOps Engineer

1.3.1 Key Personnel Requirements

The Contractor shall provide a DevSecOps Engineer who meets the following specific requirements:

Required Technical Skills

- **Infrastructure as Code:** Hands-on experience with Terraform and OpenTofu, including module development, remote state management, and workspace management
- **Configuration as Code:** Proficiency with Ansible, including playbook and role development, dynamic inventories, and Ansible Vault for secrets management
- **CI/CD:** Demonstrated experience designing and maintaining GitHub Actions workflows, including reusable workflows, matrix builds, and security gate integration
- **Containers:** Working knowledge of Docker image authoring and hardening, Kubernetes manifest and Helm chart management, and container security scanning tools (e.g., Trivy, Gype, or equivalent)
- **Security Integration:** Familiarity with SAST tools (e.g., Semgrep, Checkov, tfsec), secrets scanning (e.g., Gitleaks, Detect-Secrets), and policy-as-code frameworks (e.g., OPA/Rego)
- **Version Control:** Proficiency with Git-based workflows including branching strategies, pull request reviews, and protected branch enforcement

Preferred Skills

- Experience in a federal or highly regulated environment
- Familiarity with NIST SP 800-53, FISMA, and FedRAMP compliance requirements
- Cloud platform experience (AWS)
- Experience with secrets management tools (e.g., HashiCorp Vault)
- Scripting proficiency in Python and Bash

1.4 Deliverables and Phases

Phase 1: Onboarding and Discovery — Target Duration: 2 Weeks

- Complete all required CBO onboarding, access provisioning, and NDA/security requirements
- Conduct discovery sessions with CBO engineering leads to understand existing IaC, pipeline, and container architecture
- Review current codebase, documentation, and standards
- Produce an onboarding summary identifying gaps, quick wins, and a 90-day contribution roadmap

Task	Type	Due Date / Frequency
Onboarding completion	Deliverable	End of Week 1

Discovery summary and 90-day roadmap	Deliverable	End of Week 2
Onboarding status report	Recurring Report	Weekly, starting after award

Phase 2: Active Contribution and Development — Target Duration: 8 Weeks

- Develop and commit IaC modules, Ansible playbooks, GitHub Actions workflows, and container configurations per sprint assignments
- Integrate security gates into CI/CD pipelines
- Harden container images and Kubernetes configurations per CBO and CIS baselines
- Participate in code reviews and contribute to engineering documentation

Task	Type	Due Date / Frequency
Sprint deliverables (IaC, CaC, pipelines, containers)	Deliverable	Per sprint cadence (bi-weekly)
Security scan integration report	Deliverable	Within 4 weeks of Phase 2 start
Progress status report	Recurring Report	Weekly

Phase 3: Optimization and Hardening — Target Duration: 4 Weeks

- Refactor and optimize existing IaC and pipeline code for performance, reusability, and maintainability
- Conduct compliance review of container images and Kubernetes configurations against CBO security baselines
- Perform pipeline security gate validation and document findings
- Update and expand operational runbooks and engineering documentation

Task	Type	Due Date / Frequency
Refactored codebase components	Deliverable	Upon completion
Compliance and hardening report	Deliverable	Upon completion
Optimization status report	Recurring Report	Bi-weekly

Phase 4: Knowledge Transfer and Closeout — Target Duration: 2 Weeks

- Conduct structured knowledge transfer sessions with CBO engineering staff
- Deliver all final documentation, runbooks, and configuration artifacts

- Ensure all repositories, pipelines, and configurations are in a stable, documented, production-ready state
- Obtain CBO IRM sign-off on all deliverables

Task	Type	Due Date / Frequency
Knowledge transfer sessions	Deliverable	During Phase 4
Final documentation package	Deliverable	End of engagement
CBO IRM sign-off	Deliverable	End of engagement

1.5 Acceptance Criteria

The COR will review deliverables within five (5) business days of submission and provide the Contractor with written notification of acceptance or documented reasons for non-acceptance. The Contractor shall address any identified deficiencies within three (3) business days of receipt of non-acceptance notice.

In association with SOW paragraph 2.6.2, the project shall be deemed successful upon:

- Successful delivery and CBO IRM acceptance of all phase deliverables
- Completion of knowledge transfer sessions with CBO engineering staff
- All repositories, pipelines, and configurations left in a stable, documented, and production-ready state
- Final sign-off by CBO IRM leadership

1.6 Performance Metrics & Compliance

In addition to the requirements of SOW paragraph 2.6.3, the Contractor shall ensure all implementations align with NIST SP 800-53 Rev. 5, NIST SP 800-171, NIST SP 800-207 (Zero Trust), and FISMA 2014. Performance shall be evaluated based on:

- Timely delivery of sprint and phase deliverables per the agreed schedule
- Quality and completeness of code contributions as assessed through peer review
- Adherence to CBO engineering standards and security baselines
- Reduction in manual configuration drift and pipeline failure rates
- Compliance of IaC, containers, and pipelines with CBO and CIS security benchmarks
- Absence of critical/high vulnerabilities in delivered container images and IaC configurations

Capability	NIST SP 800-53 Control Families	NIST SP 800-171 Requirements
------------	---------------------------------	------------------------------

IaC (Terraform/OpenTofu)	CM (Configuration Mgmt), AC (Access Control)	3.4 Configuration Management
CI/CD Pipelines (GitHub Actions)	SA (System Acquisition), SI (System Integrity)	3.14 System Integrity
Containers (Docker/Kubernetes)	CM, SC (System & Comms Protection), SI	3.13 System & Comms Protection
Configuration Mgmt (Ansible)	CM-2, CM-6, CM-7	3.4.1, 3.4.2
Security Scanning (SAST/DAST)	SI-2, SI-3, RA (Risk Assessment)	3.14, 3.11 Risk Assessment
Logging and Auditing	AU (Audit and Accountability)	3.3 Audit and Accountability
Secrets Management	SC-12, SC-28	3.13.10, 3.13.16

1.7 Government Furnished Equipment and Information

Pursuant to SOW paragraph 2.5, Government-Furnished Property, the Government will provide the following to perform the tasks outlined in this Description of Work:

- CBO-issued credentials and access to source code repositories, cloud environments, and CI/CD platforms
- Access to internal systems and tools such as GitHub Enterprise, Microsoft 365, SharePoint, and VPN credentials
- Existing network diagrams, system architecture documentation, IaC codebases, and relevant configuration files
- Applicable policies, procedures, and security baselines (e.g., NIST, FISMA, IRS 1075 guidelines)
- Contact information for internal technical points of contact (POCs)